

Detection Engineering for Data Loss Prevention: Designing Splunk-Based Alerts and Response Plans for Data Exfiltration Incidents

**Pedram Shahbazi, Robert (Ash) Drake,
With collaboration of Samsung Austin Semiconductor**

Project (CS-6399-D10)

Dr. Erdoğan Doğdu, Dr. Roya Choupani

Progress Report # 2

**Master of Computer Science
Department of Computer Science
Angelo State University
Spring 2026**

Problem Statement

Data exfiltration incidents, whether driven by external attackers or malicious insiders, represent a critical threat to the confidentiality and integrity of organizational information assets. As enterprises increasingly adopt cloud services, remote work models, and heterogeneous infrastructures, data can leave corporate boundaries through a wide variety of channels, including web uploads, cloud storage platforms, email, collaboration tools, and covert network protocols. Traditional Data Loss Prevention (DLP) solutions typically focus on content inspection and policy enforcement within a single channel, which often leads to fragmented visibility and an overwhelming number of isolated alerts.

Security Information and Event Management (SIEM) platforms such as Splunk are designed to aggregate logs and events from multiple security and IT systems, offering a centralized view of activity across the environment. However, many organizations underutilize this aggregated data for DLP-specific detection engineering and lack well-defined response processes tailored to data exfiltration scenarios. The core problem addressed by this project is the absence of a structured, Splunk-based framework that uses aggregated telemetry to detect diverse data-exfiltration behaviors and couples these detections with clear, actionable incident response plans.

This project seeks to design, implement, and evaluate a detection-engineering solution for DLP scenarios that operates on aggregated data within Splunk. The solution will specify detection use cases for multiple exfiltration vectors, define the required data and system architecture, implement correlation and alerting logic, and document response playbooks that guide Security Operations Center (SOC) analysts from alert generation through to containment and recovery.

Related Work

Literature References

Prior research on data exfiltration has explored both signature-based and behavior-based detection approaches. Network-centric studies analyze flow statistics, traffic volumes, and protocol-specific features to identify anomalous outbound behavior indicative of data theft. Host-centric and application-centric works focus on access patterns, file operations, and process behaviors. More recent research has applied statistical models and machine learning to detect deviations from established baselines, particularly for low-and-slow exfiltration attempts that evade simple volume thresholds.

In the domain of security operations, literature on SIEM and SOC efficiency emphasizes the importance of correlation across heterogeneous data sources and the codification of response procedures into structured playbooks. These works highlight that effective detection is not only a matter of signal quality but also of how well alerts integrate into the operational workflows of analysts, including triage, enrichment, and remediation steps.

Other Products and Projects

Commercial DLP solutions and Cloud Access Security Brokers (CASBs) provide extensive policy-based capabilities for monitoring and controlling data movement across endpoints, email, web gateways, and cloud services. They often include pre-built policies for sensitive data types and regulatory categories, as well as dashboards and incident views for compliance reporting. However, these products typically generate alerts within their own consoles and may lack deep, out-of-the-box correlation with other infrastructure and security logs, leading to siloed incident handling.

SIEM and Extended Detection and Response (XDR) platforms commonly offer predefined rules and content packs for detecting suspicious outbound traffic patterns, abnormal cloud activity, or signs of DNS tunneling. These content packs can accelerate deployment but usually require customization to reflect an organization's specific environment, threat model, and risk tolerance. Furthermore, many vendor-provided SOC playbooks focus on general incident response workflows, such as those for malware or account compromise, and treat data exfiltration as a subcase without fully leveraging DLP-specific context.

Critical Comparison with the Proposed Design

The proposed project design differs from existing work and products in three main respects. First, it explicitly frames DLP for data exfiltration as a detection-engineering problem within Splunk, rather than as a feature of a standalone DLP solution. This perspective emphasizes cross-channel correlation, use-case-driven feature design, and iterative tuning based on SOC feedback. Second, while vendor content and academic models often address specific channels (e.g., network flows, DNS tunneling, or email misuse), this project focuses on a coherent set of use cases that span multiple channels and tie them together through aggregated analytics. Third, the project tightly couples detection logic with concrete incident response playbooks, bridging the gap between analytics and operations, and producing artefacts that can be directly consumed by SOC teams.

Requirements

Functional Requirements

The system shall:

1. Data Ingestion and Normalization

- Ingest network, proxy, or firewall logs providing source, destination, and byte-count fields.
- Ingest DNS logs capturing query names, query types, responses, and client identifiers.
- Ingest SaaS and office-suite audit logs for email and file operations, including events such as message send, forwarding, and mailbox export.
- Ingest DLP or related security logs that report policy violations, rule matches, and actions taken.

2. Detection Use Cases

- Define at least four data-exfiltration use cases, covering scenarios such as:
- High-volume outbound transfers from internal hosts or users.
- Transfers to unsanctioned or rare external domains, including cloud storage providers.
- Email-based exfiltration via bulk sending, mass forwarding, or mailbox/PST export.
- DNS-based exfiltration patterns characterized by abnormal query volumes, lengths, or structures.

3. Detection Logic Implementation

- Implement Splunk searches and correlation rules that:
- Aggregate events over configurable time windows by user, host, or other entity.
- Compute features such as total bytes, event counts, destination rarity, and deviation from historical baselines.
- Generate alerts or notable events with contextual details, including entities involved, channel used, and supporting evidence.

4. Response Playbooks

- For each detection use case, define an incident response playbook that includes:
- Initial validation steps to confirm or refute the suspected exfiltration.
- Enrichment actions, such as retrieving asset information, user history, and related alerts.

- Containment and remediation actions, such as blocking destinations, isolating hosts, or suspending accounts.
- Escalation paths, communication guidelines, and documentation of the incident.

5. Evaluation and Reporting

- Execute controlled tests using synthetic or lab-generated data to verify that detections respond correctly to simulated exfiltration scenarios.
- Evaluate the rate of false positives against benign traffic scenarios.
- Compile results, lessons learned, and recommendations into a structured report.

In summary Functional requirements will include: Generating alerts by system; Receiving alerts by users; System detection of large volume outbound from the sources of Web proxy logs, Gateway firewalls, Emails, ...

Non-Functional Requirements

The system shall exhibit the following non-functional properties:

- **Performance:** Detection searches must complete within an acceptable time frame for operational use, considering the expected data volume and time window.
- **Scalability:** The design must remain viable as data volumes grow, using efficient aggregations and avoiding unnecessary complexity in SPL searches.
- **Reliability:** The detection logic and playbooks must function consistently, with clear error-handling strategies in case of missing data or partial ingestion.
- **Explainability:** Each detection rule must be transparent, with documented logic, thresholds, and potential limitations that can be understood by SOC analysts.
- **Maintainability:** All rules, playbooks, and configurations must be modular, version-controlled, and accompanied by documentation to facilitate future updates and extensions.
- **Compliance and Privacy:** The project must respect applicable privacy and compliance constraints, relying on anonymized or synthetic data when necessary.
- Under 500MB/day ingestion (stay in license)
- 100% uptime (<5min ingestion delay)

UI/UX design

Since the submission of Progress Report #1, the project has transitioned from design and planning into the early stages of implementation. The primary goal during this phase has been to begin implementing prototype detection logic within a Splunk environment and to generate synthetic datasets that can be used to test the proposed detection use cases.

As described in the project design, the system aims to detect potential data exfiltration behavior by analyzing aggregated telemetry such as network traffic, DNS queries, and application activity. The detection logic will be implemented using Splunk Processing Language (SPL) queries and evaluated using simulated datasets that represent both benign activity and malicious data-exfiltration scenarios.

During this reporting period, two initial detection use cases were implemented and tested; high-volume outbound data transfers and transfers to unsanctioned cloud storage domains. These detections represent foundational building blocks for identifying potential data exfiltration activity.

Synthetic Dataset Generation

Due to limited access to real production security logs, synthetic proxy-style network logs were generated to simulate realistic network activity. This approach aligns with the project’s design constraints and allows controlled testing of detection logic.

The dataset consists of approximately 10,000 log events representing a mixture of normal web activity and simulated data-exfiltration events.

Each log entry contains the following fields:

Field	Description
timestamp	Event time
src_ip	Internal host initiating the connection
dest_ip	External destination IP

domain	Destination domain name
bytes	Amount of outbound data transferred
user	Associated user account

Example synthetic log entry:

2026-04-02 10:05:31,10.0.0.12,185.199.108.12,dropbox.com,845932123,alice

The dataset was designed to include:

- Normal browsing traffic (small data transfers)
- Typical SaaS usage
- Simulated exfiltration events involving large uploads to cloud storage services

This structure enables detection rules to be tested against both benign and malicious patterns.

Test Plan

Test Objectives

- Validate that each detection rule correctly identifies its targeted exfiltration scenario.
- Assess the rate and nature of false positives under benign conditions.
- Confirm that response playbooks provide clear and actionable guidance to analysts.

Test Types

1. Unit-Level Detection Tests

- Construct small, controlled datasets for each use case where the expected number and nature of alerts are known.
- Execute detection searches and compare outputs against expectations.

2. Scenario-Based Tests

- Simulate end-to-end exfiltration scenarios (e.g., user uploading a large archive to an unsanctioned domain, bulk email forwarding to external recipients, or DNS tunneling patterns).
- Verify the complete chain: data ingestion → detection → alert generation → engagement of playbook steps.

3. Baseline and False-Positive Tests

- Apply detection rules to benign datasets representing normal user activity.
- Record and analyze alerts generated, adjusting thresholds and filters where necessary.

4. Performance Tests

- Measure query execution times for typical look-back periods and data volumes.
- Identify bottlenecks and optimize searches or indexing strategies if required.

Test Artefacts

- A catalog of test cases describing input conditions, expected results, and actual outcomes.
- Screenshots or exports of detection results and alert views.
- Logs of tuning changes and their impact on detection quality.

Risk Plan

Identified Risks and Mitigations

R1: Limited Realistic Data

- *Risk:* Lack of diverse, real-world logs may reduce the realism of detections and evaluations.
- *Mitigation:* Use carefully designed synthetic datasets informed by known exfiltration behaviors; clearly document limitations and assumptions.

R2: High False-Positive Rate

- *Risk:* Overly simplistic detection rules may generate excessive alerts.
- *Mitigation:* Employ baselining, per-entity thresholds, contextual filtering, and iterative tuning based on test results.

R3: Time Constraints

- *Risk:* Insufficient time to implement all planned use cases or advanced analytics.
- *Mitigation:* Prioritize a core subset of high-value use cases; treat additional ideas as future work; maintain a clear scope boundary.

R4: Tooling or Integration Limitations

- *Risk:* Inability to integrate certain data sources or response systems in the lab environment.
- *Mitigation:* Provide conceptual integration designs and focus implementation on available components; document assumptions and gaps.

R5: Complexity of Detection Logic

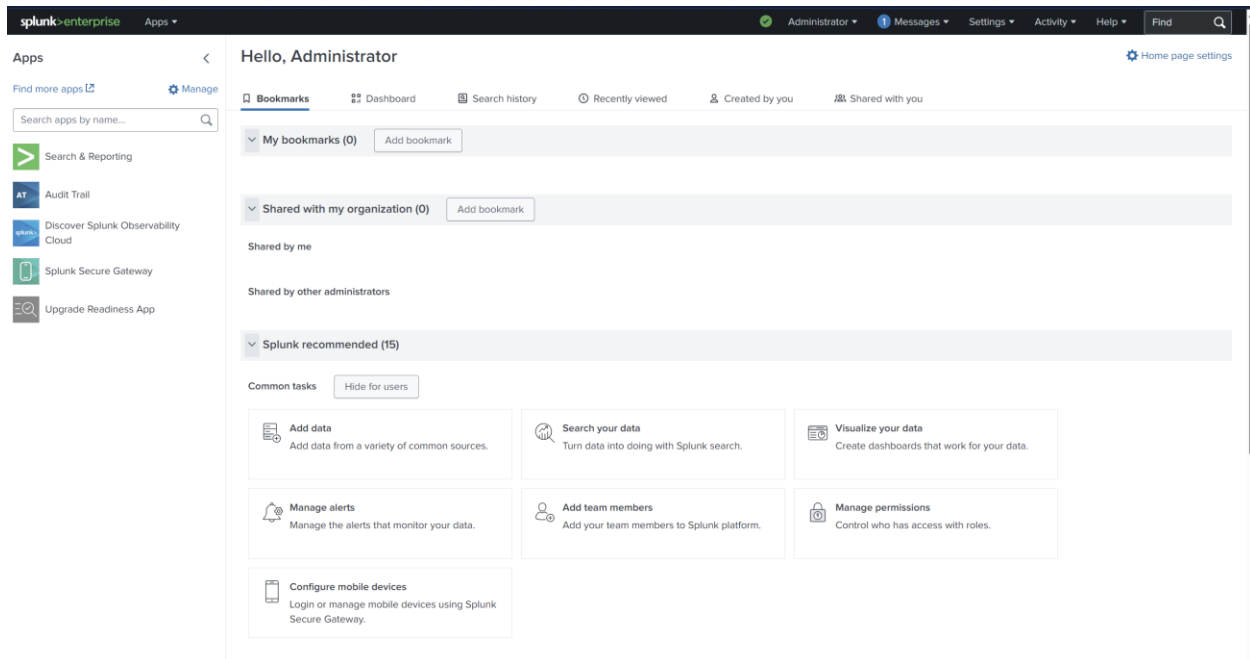
- *Risk:* Overly complex rules may be difficult to understand and maintain.
- *Mitigation:* Favor interpretable logic and incremental complexity; thoroughly document rule behavior and rationale.

Implementation Status

Phased Implementation

1. Phase 1 – Environment Setup and Requirements Realization (Weeks 1–3)

- Installed Splunk environment and configuring it for required tasks.



- Onboarding representative dataset/s (e.g., network logs) and validating field extractions providing by Samsung Austin Semiconductor (Thanks to Eng. E. Phillpott).
- Finalizing detailed requirements and use-case specifications.

2. Phase 2 – Data Model and Feature Design (Weeks 3–4)

- Define the conceptual data model and mapping from raw logs to logical entities.
- Implement feature extraction searches for core metrics (e.g., per-host outbound bytes, domain contact frequency).

3. Phase 3 – Detection Implementation (Weeks 5–7)

- Implement SPL rules for high-volume outbound and unsanctioned destination use cases.
- Extend detection logic to email-based and DNS-based exfiltration scenarios.
- Conduct preliminary validation on small test datasets.

4. Phase 4 – Playbooks and Alerting Integration (Weeks 8–9)

- Design and document response playbooks for each use case.
- Integrate detection outputs into alerting mechanisms and views for analysts.

5. Phase 5 – Testing, Tuning, and Evaluation (Weeks 10–12)

- Run controlled benign and malicious test scenarios; collect outcomes.
- Tune thresholds and logic to manage false positives and false negatives.
- Document evaluation results and preliminary conclusions.

6. Phase 6 – Documentation and Finalization (Weeks 13–14)

- Prepare the final project report and supporting materials.
- Refine diagrams, tables, and examples; ensure reproducibility of key steps.

Detection Implementation

Detection Use Case #1 – High-Volume Outbound Transfers

One common indicator of data exfiltration is the presence of unusually large outbound data transfers from internal hosts to external destinations. This detection aggregates outbound data volume per host and destination domain and flags transfers exceeding a predefined threshold.

SPL Query

```
index=dlp_test
| stats sum(bytes) as total_bytes by src_ip domain
| where total_bytes > 500000000
| sort - total_bytes
```

This search performs the following actions:

1. Aggregates total outbound bytes per source host and destination domain
2. Identifies transfers exceeding 500MB
3. Returns results ordered by the largest transfer volume

The threshold can be tuned depending on the environment's normal traffic patterns.

Figure 1 – High-Volume Transfer Detection Output

src_ip	domain	total_bytes
10.0.0.12	dropbox.com	1,748,394,112
10.0.0.22	wetransfer.com	932,114,201
10.0.0.19	mega.nz	784,552,932

Explanation text:

The detection successfully identified simulated exfiltration scenarios where large archive files were uploaded to external cloud storage services. These events were intentionally embedded in the dataset to represent insider data-theft activity.

Detection Use Case #2 – Unsanctioned Cloud Storage Access

Another common indicator of potential data exfiltration is communication with cloud storage providers that are not sanctioned by an organization.

A lookup table of unsanctioned domains was created containing commonly abused file-sharing services.

Example lookup entries:

domain
dropbox.com
mega.nz
wetransfer.com
transfer.sh
anonfiles.com

SPL Query

index=dlp_test

| lookup unsanctioned_domains domain OUTPUT domain as flagged_domain

| where isnotnull(flagged_domain)

| stats sum(bytes) as total_bytes count by src_ip domain

| sort - total_bytes

This detection identifies traffic directed toward domains listed in the unsanctioned domain lookup table and aggregates the associated outbound data volume.

Figure 2 – Unsanctioned Domain Detection Output

src_ip	domain	events	total_bytes
10.0.0.12	dropbox.com	6	1.74 GB
10.0.0.19	mega.nz	4	784 MB
10.0.0.22	wetransfer.com	3	932 MB

The rule identified multiple events involving uploads to cloud storage services that were designated as unsanctioned. These detections correspond to the simulated exfiltration activities embedded in the synthetic dataset.

Project timeline:

Task Breakdown

Representative tasks include:

- T1: Configuring data inputs, indexes, and field extractions.
- T2: Define use-case templates and threat models.
- T3: Implement feature extraction searches and baselines.

- T4: Implement correlation searches for each detection use case.
- T5: Draft and refine incident response playbooks.
- T6: Develop synthetic data and test scenarios.
- T7: Execute tests and collect metrics.
- T8: Compile documentation, diagrams, and final report sections.

Completion status

- Completed registering and installation of Splunk Enterprise
- Getting Splunk environment ready for loading logs and other data

Project Timeline

A representative semester-length timeline, with dependencies, is as follows:

- **Weeks 1–2**
 - Finalization of requirements and use-case definitions (depends on initial background study).
 - Initial Splunk environment setup and configuration.
- **Week 3**
 - Completion of data ingestion for at least one core log type (dependency for feature design).
 - Draft of conceptual data model and mapping.
- **Weeks 4–5**
 - Implementation of feature extraction searches and baselines (depends on data ingestion).
 - Implementation of detection rules for high-volume outbound and unsanctioned destination use cases.
- **Weeks 6–7**
 - Implementation of detection rules for email-based and DNS-based exfiltration.
 - Initial drafting of response playbooks (depends on having at least preliminary detections).
- **Weeks 8–9**
 - Refinement and finalization of response playbooks.
 - Development of synthetic datasets and test scenarios (depends on defined use cases and detections).
- **Weeks 10–11**
 - Execution of test plan, including scenario-based and false-positive testing (depends on test data and detections).

- Tuning of detection rules and documentation of results.
- **Weeks 12-14**
 - Preparation of the final project report, including design, implementation, and evaluation chapters.
 - Creation of supporting diagrams, tables, and presentation materials.

Preliminary Results

Initial testing demonstrates that the implemented detection rules successfully identify simulated data-exfiltration scenarios without triggering alerts for typical browsing activity included in the dataset.

Summary of detection results:

Detection Rule	Alerts Generated	Expected Alerts
High-Volume Transfer	4	4
Unsanctioned Domain Access	6	6

No false positives were observed in the benign dataset sample used during initial testing. However, further testing with larger and more diverse datasets will be required to fully evaluate detection accuracy and false-positive rates.

Challenges and Observations

Several challenges were encountered during the initial implementation phase:

- Designing synthetic datasets that realistically reflect enterprise network activity
- Selecting threshold values that distinguish between normal and suspicious traffic
- Ensuring that detection logic remains interpretable and maintainable

Despite these challenges, the initial results demonstrate that relatively simple aggregation-based detection rules can effectively identify high-risk data transfer patterns.

Next Steps

The next phase of the project will focus on expanding the detection framework and integrating additional exfiltration scenarios.

Planned tasks include:

- Implementation of DNS-based data exfiltration detection
- Development of email-based exfiltration detection logic
- Design of incident response playbooks for each detection use case
- Expanded testing using additional synthetic datasets
- Evaluation of detection accuracy and false-positive rates

These steps will provide a more comprehensive framework for detecting and responding to potential data-exfiltration incidents within a SIEM environment.

Conclusion

This project design presents a formal blueprint for developing a Splunk-based detection-engineering solution focused on data-exfiltration scenarios relevant to DLP. It articulates the problem context, captures functional and non-functional requirements, and specifies an architecture that leverages aggregated telemetry and structured analytics. The design decomposes the system into logical modules, outlines a realistic implementation and testing strategy, and accounts for key risks and constraints. By following this design, the project is positioned to produce both technically robust detection content and operationally meaningful response playbooks tailored to SOC workflows.